

ЛАБОРАТОРНА РОБОТА № 5

Аутентифікація та авторизація. Робота з Web API. JSON Web Token.

Варіант №8

Мета: набути навичок роботи з механізмами аутентифікації та авторизації користувачів в ASP.NET, набути навичок роботи з Web API.

Завдання 1.

Реалізувати реєстрацію, автентифікацію та авторизацію користувача з використанням пакету Microsoft Identity.

Після конфігурації Identity, реалізуйте наступні функціональності:

1. Реєстрація користувача ([приклад](#))
 - a. встановити вимогу по унікальності електронної адреси користувача
 - b. встановити вимоги до пароля: не коротший за 8 символів, містить цифри та літери, обов'язково містить хоча б одну літеру в верхньому регістрі
 - c. реалізувати поле для підтвердження введеного паролю
2. Автентифікація користувача (Login)
3. Вихід користувача (Logout)
4. Особистий кабінет користувача, де він матиме змогу переглядати або змінювати дані про себе.

Лістинг AccountController

```
using Microsoft.AspNetCore.Authorization;
using Microsoft.AspNetCore.Identity;
using Microsoft.AspNetCore.Mvc;
using AbsoluteCinema.Models.ViewModels;
using System.Threading.Tasks;
using System.Linq;

namespace AbsoluteCinema.Controllers
{
    [Authorize]
    public class AccountController : Controller
    {
```

					ДУ «Житомирська політехніка».25.121.8.000 – Лр5						
Змн.	Арк.	№ докум.	Підпис	Дата							
Розроб.		Зармбицький Є.Ю			Звіт з лабораторної роботи			Лім.	Арк.	Аркушів	
Перевір.		Українець М.О.								1	15
Керівник								ФІКТ Гр. ІПЗ-22-2			
Н. контр.											
Зав. каф.											

```

private readonly UserManager<IdentityUser> userManager;
private readonly SignInManager<IdentityUser> signInManager;

public AccountController(UserManager<IdentityUser> userMgr,
    SignInManager<IdentityUser> signInMgr)
{
    userManager = userMgr;
    signInManager = signInMgr;
}

[AllowAnonymous]
public IActionResult Login(string returnUrl)
{
    return View(new LoginModel { ReturnUrl = returnUrl });
}

[HttpPost]
[AllowAnonymous]
[ValidateAntiForgeryToken]
public async Task<ActionResult> Login(LoginModel loginModel)
{
    if (ModelState.IsValid)
    {
        IdentityUser? user = await userManager.FindByEmailAsync(loginModel.Email);

        if (user != null)
        {
            await signInManager.SignOutAsync();

            var result = await signInManager.PasswordSignInAsync(user,
                loginModel.Password, isPersistent: false, lockoutOnFailure: false);

            if (result.Succeeded)
            {
                return Redirect(loginModel.ReturnUrl ?? "/");
            }
        }

        ModelState.AddModelError("", "Невірний Email або пароль.");
    }
    return View(loginModel);
}

[AllowAnonymous]
public IActionResult Register() => View(new RegisterModel());

[HttpPost]
[AllowAnonymous]
[ValidateAntiForgeryToken]
public async Task<ActionResult> Register(RegisterModel model)
{
    if (ModelState.IsValid)

```

		Зарембичський Є.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				2
Змн.	Арк.	№ докум.	Підпис	Дата		

```

{
    var user = new IdentityUser { UserName = model.Email, Email = model.Email };
    var result = await userManager.CreateAsync(user, model.Password);

    if (result.Succeeded)
    {
        await signInManager.SignInAsync(user, isPersistent: false);
        return RedirectToAction("Profile");
    }

    foreach (var error in result.Errors)
    {
        ModelState.AddModelError("", error.Description);
    }
}

return View(model);
}

public async Task<RedirectResult> Logout(string returnUrl = "/")
{
    await signInManager.SignOutAsync();
    return Redirect(returnUrl);
}

public async Task<IActionResult> Profile()
{
    var user = await userManager.GetUserAsync(User);
    if (user == null) return NotFound();

    var model = new ProfileModel { Email = user.Email ?? string.Empty };
    return View(model);
}

[HttpPost]
[ValidateAntiForgeryToken]
public async Task<IActionResult> Profile(ProfileModel model)
{
    var user = await userManager.GetUserAsync(User);
    if (user == null) return NotFound();

    if (!string.IsNullOrEmpty(model.NewPassword) || !string.IsNullOrEmpty(model.ConfirmNewPassword))
    {
        if (model.NewPassword != model.ConfirmNewPassword)
        {
            ModelState.AddModelError("", "Новий пароль та його підтвердження не збігаються.");
            model.Email = user.Email ?? string.Empty;
            return View(model);
        }

        var changePasswordResult = await userManager.ChangePasswordAsync(user, model.CurrentPassword, model.NewPassword);

        if (!changePasswordResult.Succeeded)
        {
            foreach (var error in changePasswordResult.Errors)
            {

```

		Зарембичський Є.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				3
Змн.	Арк.	№ докум.	Підпис	Дата		

```

        ModelState.AddModelError("", error.Description);
    }

    model.Email = user.Email ?? string.Empty;
    return View(model);
}

await signInManager.RefreshSignInAsync(user);
TempData["message"] = "Ваш пароль успішно змінено!";
return RedirectToAction("Profile");
}

TempData["message"] = "Дані оновлено успішно.";
return RedirectToAction("Profile");
}
}
}

```

Лістинг Login.cshtml

@model AbsoluteCinema.Models.ViewModels.LoginModel

```

@{
    ViewData["Title"] = "Login";
    Layout = "_Layout";
}

```

```

<div class="container my-5">
    <div class="row justify-content-center">
        <div class="col-md-6">
            <h2 class="mb-4 text-center">User Login</h2>

            <div class="alert alert-danger" asp-validation-summary="ModelOnly"></div>

            <form asp-controller="Account" asp-action="Login" method="post">
                <input type="hidden" asp-for="ReturnUrl" />

                <div class="mb-3">
                    <label asp-for="Email" class="form-label"></label>
                    <input asp-for="Email" class="form-control" />
                    <span asp-validation-for="Email" class="text-danger"></span>
                </div>

                <div class="mb-3">
                    <label asp-for="Password" class="form-label"></label>
                    <input asp-for="Password" class="form-control" />
                    <span asp-validation-for="Password" class="text-danger"></span>
                </div>

                <div class="d-grid gap-2">
                    <button class="btn btn-primary btn-lg" type="submit">Log In</button>
                    <a asp-action="Register" asp-route-returnUrl="@Model.ReturnUrl" class="btn btn-outline-secondary">Create Account</a>
                </div>
            </form>

```

		Зарембицький Є.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				4
Змн.	Арк.	№ докум.	Підпис	Дата		

```

        </div>
    </div>
</div>

Лістинг Profile.cshtml

@model AbsoluteCinema.Models.ViewModels.ProfileModel

@{
    ViewData["Title"] = "User Profile";
    Layout = "_Layout";
}

<div class="container my-5">
    <div class="row justify-content-center">
        <div class="col-md-8">
            <h2 class="mb-4">Особистий кабінет</h2>

            @if (TempData["message"] != null)
            {
                <div class="alert alert-success">@TempData["message"]</div>
            }

            <div class="card shadow-sm">
                <div class="card-header bg-primary text-white">
                    Зміна пароля
                </div>
                <div class="card-body">
                    <div class="alert alert-danger" asp-validation-summary="ModelOnly"></div>

                    <form asp-action="Profile" method="post">

                        <div class="mb-3">
                            <label asp-for="Email" class="form-label"></label>
                            <input asp-for="Email" class="form-control" readonly />
                        </div>

                        <h5 class="mt-4 mb-3">Змінити пароль (залиште порожнім, якщо не потрібно)</h5>

                        <div class="mb-3">
                            <label asp-for="NewPassword" class="form-label"></label>
                            <input asp-for="NewPassword" class="form-control" />
                            <span asp-validation-for="NewPassword" class="text-danger"></span>
                        </div>

                        <div class="mb-3">
                            <label asp-for="ConfirmNewPassword" class="form-label"></label>
                            <input asp-for="ConfirmNewPassword" class="form-control" />
                            <span asp-validation-for="ConfirmNewPassword" class="text-danger"></span>
                        </div>

                        <h5 class="mt-4 mb-3">Підтвердження</h5>

```

		Зарембичський Є.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				5
Змн.	Арк.	№ докум.	Підпис	Дата		

```

        <div class="mb-3">
            <label asp-for="CurrentPassword" class="form-label"></label>
            <input asp-for="CurrentPassword" class="form-control" />
            <span asp-validation-for="CurrentPassword" class="text-danger"></span>
            <small class="text-muted">Для збереження змін завжди потрібен поточний пароль.</small>
        </div>

        <div class="d-grid mt-4">
            <button class="btn btn-warning btn-lg" type="submit">Зберегти зміни</button>
        </div>
    </form>
</div>
</div>
</div>
</div>
</div>

```

Лістинг Register.cshtml

@model AbsoluteCinema.Models.ViewModels.RegisterModel

```

@{
    ViewData["Title"] = "Register";
    Layout = "_Layout";
}

```

```

<div class="container my-5">
    <div class="row justify-content-center">
        <div class="col-md-6">
            <h2 class="mb-4 text-center">User Registration</h2>

            <div class="alert alert-danger" asp-validation-summary="ModelOnly"></div>

            <form asp-action="Register" method="post">

                <div class="mb-3">
                    <label asp-for="Email" class="form-label"></label>
                    <input asp-for="Email" class="form-control" />
                    <span asp-validation-for="Email" class="text-danger"></span>
                </div>

                <div class="mb-3">
                    <label asp-for="Password" class="form-label"></label>
                    <input asp-for="Password" class="form-control" />
                    <span asp-validation-for="Password" class="text-danger"></span>
                    <small class="text-muted">Пароль має містити: мін. 8 символів, велику літеру, цифру.</small>
                </div>

                <div class="mb-3">
                    <label asp-for="ConfirmPassword" class="form-label"></label>
                    <input asp-for="ConfirmPassword" class="form-control" />
                    <span asp-validation-for="ConfirmPassword" class="text-danger"></span>
                </div>
            </form>
        </div>
    </div>
</div>

```

		Зарембичський С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				6
Змн.	Арк.	№ докум.	Підпис	Дата		

```

<div class="d-grid">
  <button class="btn btn-success btn-lg" type="submit">Register</button>
</div>
</form>
</div>
</div>
</div>

```

User Registration

Електронна пошта

Пароль

Пароль має містити: мін. 8 символів, велику літеру, цифру.

Підтвердження паролю

Register

 indiraptor63583@gmail.com

Особистий кабінет

Зміна пароля

Електронна пошта (не можна змінити)

Змінити пароль (залиште порожнім, якщо не потрібно)

Новий пароль

Підтвердіть новий пароль

Підтвердження

Поточний пароль

Для збереження змін завжди потрібен поточний пароль.

Зберегти зміни

 indiraptor63583@gmail.com

 Особистий кабінет

 Вихід

		Зарембицький С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				7
Змн.	Арк.	№ докум.	Підпис	Дата		

User Login

Email

indiraptor63583@gmail.com

Password

••••••••

Log In

Create Account

Рис. 1-4. Результат роботи програмного коду

Завдання 2.

В рішенні створити новий WebAPI проект. Цей проект повинен реалізовувати всі функціональності, які наявні в MVC проекті у вигляді REST-ендпоінтів. Для кращої організації і перевикористання коду слід перенести файли для роботи з БД (репозиторії, контексти, моделі) в окрему бібліотеку і додати посилання на неї в MVC та WebAPI проектах. Встановіть необхідні залежності для проекту бібліотеки.

Після цього налаштуйте ConnectionString'и для створених БД для WebAPI проекту в файлі appsettings.json. Таким чином, після перенесення файлів для роботи з БД в окрему бібліотеку ми можемо використовувати всі необхідні сервіси в обох проектах.

		Зарембицький С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				8
Змн.	Арк.	№ докум.	Підпис	Дата		

Лістинг AccountController:

```
using Microsoft.AspNetCore.Authorization;
using Microsoft.AspNetCore.Identity;
using Microsoft.AspNetCore.Mvc;
using RestAPI.Models.ViewModels;
using System.Threading.Tasks;
using System.Linq;

namespace RestAPI.Controllers
{
    [ApiController]
    [Route("api/[controller]")]
    public class AccountController : ControllerBase
    {
        private readonly UserManager<IdentityUser> userManager;
        private readonly SignInManager<IdentityUser> signInManager;

        public AccountController(UserManager<IdentityUser> userMgr,
                                SignInManager<IdentityUser> signInMgr)
        {
            userManager = userMgr;
            signInManager = signInMgr;
        }

        [HttpPost("Register")]
        [AllowAnonymous]
        public async Task<ActionResult> Register([FromBody] RegisterModel model)
        {
            if (!ModelState.IsValid) return BadRequest(ModelState);

            var user = new IdentityUser { UserName = model.Email, Email = model.Email };
            var result = await userManager.CreateAsync(user, model.Password);

            if (result.Succeeded)
            {
                return Ok(new { message = "Registration successful." });
            }

            var errors = result.Errors.Select(e => e.Description);
            return BadRequest(new { errors });
        }

        [HttpPost("Login")]
        [AllowAnonymous]
        public async Task<ActionResult> Login([FromBody] LoginModel loginModel)
        {
            if (!ModelState.IsValid) return BadRequest(ModelState);

            IdentityUser? user = await userManager.FindByEmailAsync(loginModel.Email);

            if (user == null)
                return Unauthorized(new { message = "Invalid email or password." });

            var result = await signInManager.CheckPasswordSignInAsync(user, loginModel.Password, false);

            if (result.Succeeded)
            {
                return Ok(new { message = "Login successful.", user_id = user.Id });
            }

            return Unauthorized(new { message = "Invalid email or password." });
        }

        [HttpPost("Logout")]
        public IActionResult Logout()
        {
            return Ok(new { message = "Logged out." });
        }

        [HttpGet("Profile")]
        public async Task<ActionResult> GetProfile()
        {
            var user = await userManager.GetUserAsync(User);
            if (user == null) return NotFound();

            return Ok(new { user.Email, user.UserName });
        }
    }
}
```

		Заремицький С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				9
Змн.	Арк.	№ докум.	Підпис	Дата		

```
}
}
}
```

Лістинг BookingController:

```
using Microsoft.AspNetCore.Mvc;
using RestAPI.Models;
using System.Linq;
using System.Collections.Generic;

namespace RestAPI.Controllers
{
    [ApiController]
    [Route("api/[controller]")]
    public class BookingController : ControllerBase
    {
        [HttpGet("Seats")]
        public IActionResult GetBookedSeats()
        {
            return Ok(BookingDataStore.GetBookedSeats());
        }

        [HttpPost("Confirm")]
        public IActionResult ConfirmBooking([FromBody] List<Seat> seats)
        {
            if (seats == null || !seats.Any())
            {
                return BadRequest(new { message = "No seats provided for booking." });
            }

            BookingDataStore.AddPermanentBookings(seats);

            return Ok(new { message = $"Booking confirmed for {seats.Count} seat(s)!", seats });
        }
    }
}
```

Лістинг FilmsController:

```
using Microsoft.AspNetCore.Mvc;
using Microsoft.EntityFrameworkCore;
using RestAPI.Models;
using RestAPI.Models.ViewModels;
using System.Linq;

namespace RestAPI.Controllers
{
    [ApiController]
    [Route("api/[controller]")]
    public class FilmsController : ControllerBase
    {
        private readonly ICinemaRepository repository;
        private const int PageSize = 3;

        public FilmsController(ICinemaRepository repo)
        {
            repository = repo;
        }

        [HttpGet]
        public IActionResult GetFilms(string? genre, int page = 1)
        {
            var filmsQuery = repository.Films
                .Where(f => genre == null || f.Genre == genre)
                .OrderBy(f => f.Title);

            var viewModel = new FilmsListViewModel
            {
                Films = filmsQuery
                    .Skip((page - 1) * PageSize)
                    .Take(PageSize)
                    .ToList(),
                PagingInfo = new PagingInfo
                {
                    CurrentPage = page,
```

		Зарембичський С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				10
Змн.	Арк.	№ докум.	Підпис	Дата		

```

        ItemsPerPage = PageSize,
        TotalItems = filmsQuery.Count()
    },
    CurrentGenre = genre
};
return Ok(viewModel);
}

[HttpGet("{id}")]
public IActionResult GetFilm(long id)
{
    var film = repository.Films
        .Include(f => f.Screenings)
        .FirstOrDefault(f => f.FilmID == id);

    if (film == null) return NotFound();
    return Ok(film);
}

[HttpPost]
public IActionResult CreateFilm([FromBody] Film film)
{
    if (!ModelState.IsValid) return BadRequest(ModelState);
    repository.CreateFilm(film);
    return CreatedAtAction(nameof(GetFilm), new { id = film.FilmID }, film);
}

[HttpPut]
public IActionResult UpdateFilm([FromBody] Film film)
{
    if (film.FilmID == 0 || !ModelState.IsValid) return BadRequest(ModelState);
    repository.SaveFilm(film);
    return Ok(film);
}

[HttpDelete("{id}")]
public IActionResult DeleteFilm(long id)
{
    Film? film = repository.Films.FirstOrDefault(f => f.FilmID == id);
    if (film == null) return NotFound();

    repository.DeleteFilm(film);
    return NoContent();
}
}
}

```

ЛІСТИНГ ScreeningsController:

```

using Microsoft.AspNetCore.Mvc;
using Microsoft.EntityFrameworkCore;
using RestAPI.Models;
using System.Linq;

namespace RestAPI.Controllers
{
    [ApiController]
    [Route("api/[controller]")]
    public class ScreeningsController : ControllerBase
    {
        private readonly ICinemaRepository repository;

        public ScreeningsController(ICinemaRepository repo)
        {
            repository = repo;
        }

        [HttpGet]
        public IActionResult GetScreenings()
        {
            return Ok(repository.Screenings);
        }

        [HttpGet("{id}")]
        public IActionResult GetScreening(long id)
        {
            var screening = repository.Screenings
                .Include(s => s.Film)
                .FirstOrDefault(s => s.ScreeningID == id);

```

		Зарембичський Є.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				11
Змн.	Арк.	№ докум.	Підпис	Дата		

```

        if (screening == null) return NotFound();
        return Ok(screening);
    }

    [HttpPost]
    public IActionResult CreateScreening([FromBody] Screening screening)
    {
        if (!ModelState.IsValid) return BadRequest(ModelState);
        repository.CreateScreening(screening);
        return CreatedAtAction(nameof(GetScreening), new { id = screening.ScreeningID }, screening);
    }

    [HttpPut]
    public IActionResult UpdateScreening([FromBody] Screening screening)
    {
        if (screening.ScreeningID == 0 || !ModelState.IsValid) return BadRequest(ModelState);
        repository.SaveScreening(screening);
        return Ok(screening);
    }

    [HttpDelete("{id}")]
    public IActionResult DeleteScreening(long id)
    {
        Screening? screening = repository.Screenings.FirstOrDefault(s => s.ScreeningID == id);
        if (screening == null) return NotFound();

        repository.DeleteScreening(screening);
        return NoContent();
    }
}
}
}

```

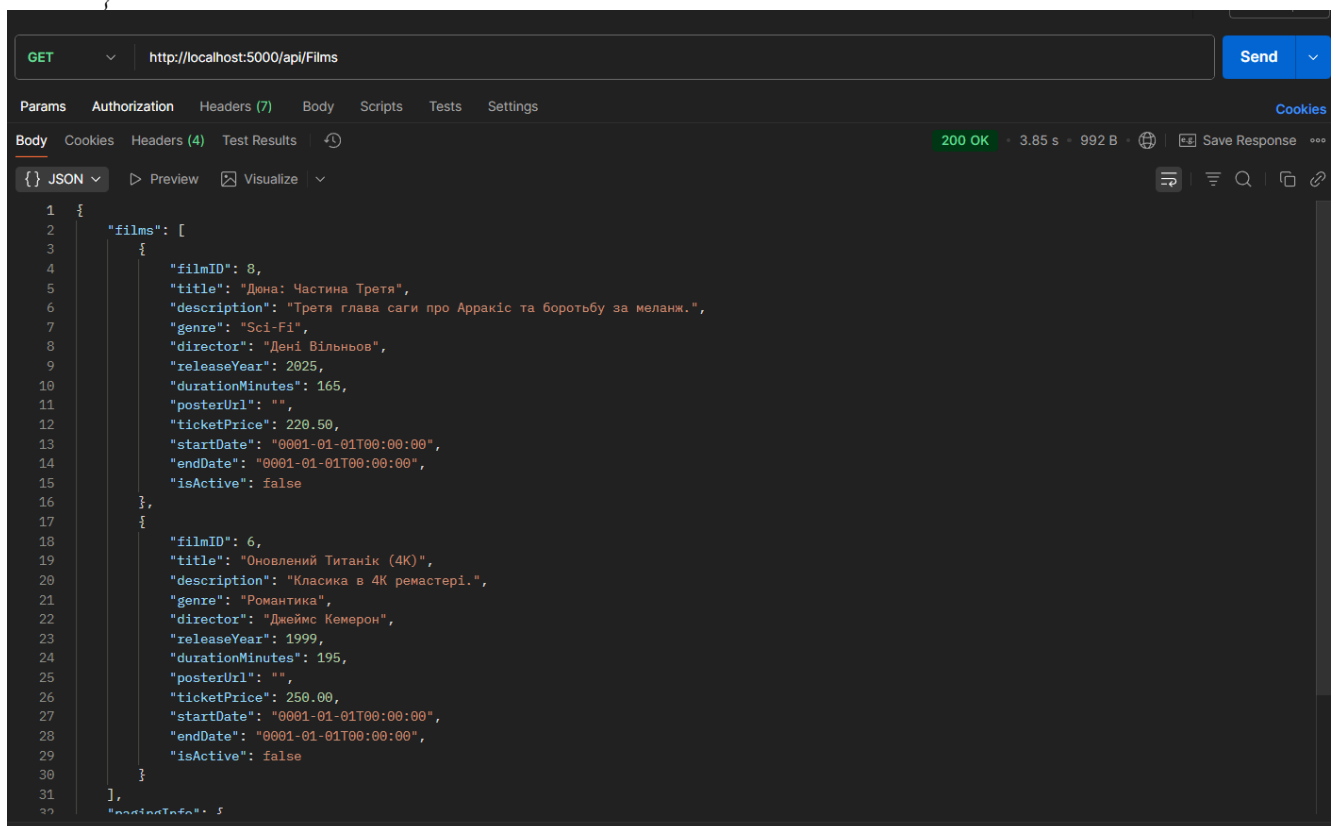


Рис. 5. Перегляд у postman

Реалізуйте автентифікацію та авторизацію користувача з використанням механізму JSON Web Token (JWT). Вона повинна працювати наступним чином:

1. Клієнт відправляє запит на login-ендпоїнт зі своїм логіном та паролем.

		Зарембицький С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				12
Змн.	Арк.	№ докум.	Підпис	Дата		

2. Якщо користувач з таким логіном та паролем існує, тоді сервер повинен повернути згенерований JSON Web Token.
3. Для отримання доступу до дій, які вимагають авторизації, клієнт відправляє в запиті заголовок Authorization зі значенням Bearer TokenValue, де TokenValue – токен, який було згенеровано під час автентифікації.
4. Якщо токен валідний – сервер виконає запит, інакше поверне помилку 401 Unauthorized.

Лістинг AccountController.cs

```
using Microsoft.AspNetCore.Authorization;
using Microsoft.AspNetCore.Identity;
using Microsoft.AspNetCore.Mvc;
using RestAPI.Models.ViewModels;
using System.Threading.Tasks;
using System.Linq;
using System.IdentityModel.Tokens.Jwt;
using System.Security.Claims;
using Microsoft.IdentityModel.Tokens;
using System.Text;
using Microsoft.Extensions.Configuration;

namespace RestAPI.Controllers
{
    [ApiController]
    [Route("api/[controller]")]
    [Authorize]
    public class AccountController : ControllerBase
    {
        private readonly UserManager<IdentityUser> userManager;
        private readonly IConfiguration configuration;
        public AccountController(UserManager<IdentityUser> userMgr, IConfiguration config)
        {
            userManager = userMgr;
            configuration = config;
        }
        private string GenerateJwtToken(IdentityUser user)
        {
            var jwtSettings = configuration.GetSection("JwtSettings");
            var key = new SymmetricSecurityKey(Encoding.UTF8.GetBytes(jwtSettings["Key"]));

            var claims = new List<Claim>
            {
                new Claim(ClaimTypes.NameIdentifier, user.Id),
                new Claim(ClaimTypes.Email, user.Email),
                new Claim(ClaimTypes.Name, user.UserName ?? user.Email)
            };

            var credentials = new SigningCredentials(key, SecurityAlgorithms.HmacSha256);

            var expiryMinutes = double.Parse(jwtSettings["DurationInMinutes"]);
            var expiry = DateTime.UtcNow.AddMinutes(expiryMinutes);

            var token = new JwtSecurityToken(
                issuer: jwtSettings["Issuer"],
                audience: jwtSettings["Audience"],
                claims: claims,
                expires: expiry,
                signingCredentials: credentials);

            return new JwtSecurityTokenHandler().WriteToken(token);
        }

        [HttpPost("Register")]
        [AllowAnonymous]
        public async Task<ActionResult> Register([FromBody] RegisterModel model)
        {

```

		Зарембичський С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				13
Змн.	Арк.	№ докум.	Підпис	Дата		

[illegible]

		Зарембицький Є.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				14
Змн.	Арк.	№ докум.	Підпис	Дата		

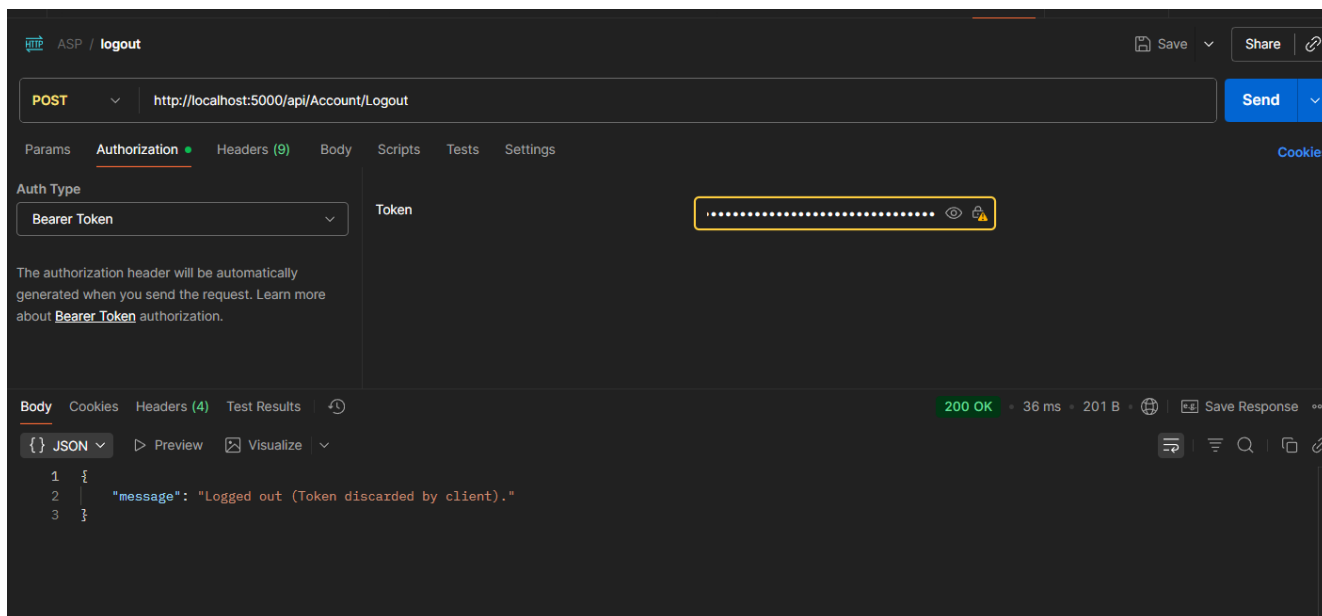
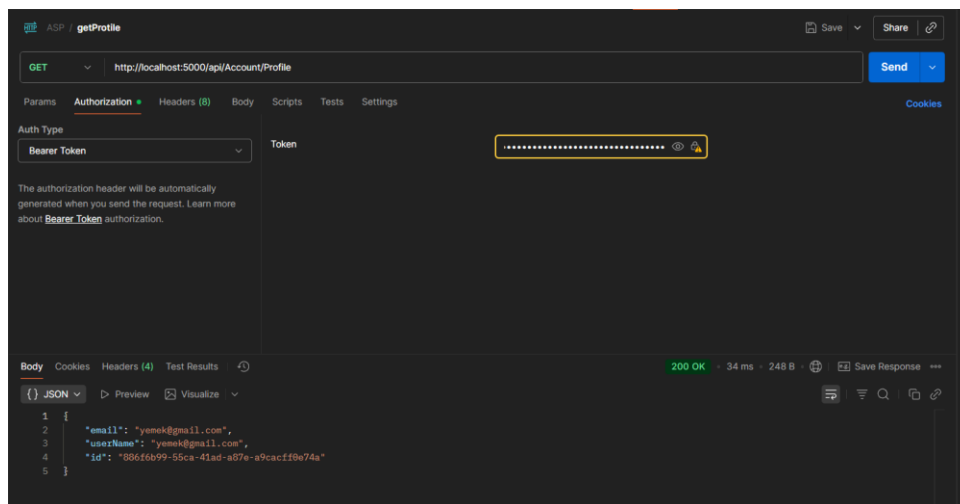
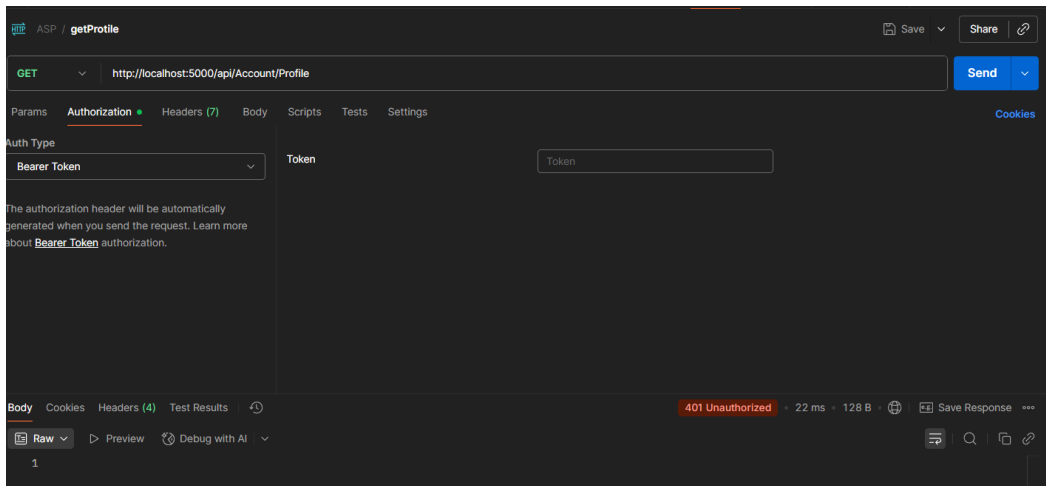


Рис. 6-9. Результат виконання програмного коду

Висновок: я набув навичок роботи з механізмами аутентифікації та авторизації користувачів в ASP.NET, набути навичок роботи з Web API.

		Зарембичський С.Ю.			ДУ «Житомирська політехніка».25.121.8.000 – Лр5	Арк.
		Українець М.О.				15
Змн.	Арк.	№ докум.	Підпис	Дата		